



De 3/5 a producible.

Los 26 hallazgos de la auditoría, mapeados a ~22 PRs en 5 fases, en orden de palanca y dependencia. Una unidad de trabajo por PR, verde en cada cierre.



CAMINO CRÍTICO

El orden importa: destrabar, cimentar el equipo, encender la memoria, escalar, abrir.



Regla de secuencia: F0 es prerequisite de todo (sin release no hay a qué versionar los avances; sin DR hay riesgo existencial). Dentro de F2, el harness va ANTES de encender el default semántico (medir antes de flippear). F1 y F2 son en gran parte paralelizables si hay manos; F3 se apoya en la tenancy de F1 (cuota por project_id).

La convención de Musubi, aplicada.

SDD Lo sustancial (tenancy, identidad, semántico) pasa por proposal→spec→design→tasks→verify. Lo mecánico va en PR directo.	1 PR = 1 UNIDAD Cada PR es atómico y revisable; go test ./... + lint verde y golden intacto antes de mergear.	EVIDENCIA Cada PR referencia el/los hallazgo(s) que cierra y su file:line; el criterio unificado es la vara de aceptación.	MEMORIA Al cerrar cada fase, se guarda el avance en el cerebro y se marca el hallazgo como resuelto contra audit/2026-07-08.
---	---	--	--

DESTABAR **Release verificable + no perder la memoria**

días, no semanas

Convertir "main" en producto con release firmada desde una sola fuente de verdad, y eliminar el riesgo existencial de perder la memoria central.

16.0a Cortar release + unificar versión

PR directo

M

Mover CHANGELOG [Unreleased] → [X.Y.Z] , taggear, dejar que `release.yml` publique C1–C4+P2. Derivar `versioninfo.json/.syso` del tag en el pipeline; test de consistencia `versioninfo==tag` . Seguir: firma cosign + SBOM + provenance.

cierra: ● release/versionado/supply-chain

16.0b DR del nodo central

PR directo

M

systemd `.timer` con `VACUUM INTO` a almacenamiento off-host + retención; migrar `backupDB()` de `io.Copy` a snapshot consistente; runbook de RESTORE probado end-to-end. (Evaluar Litestream WAL-shipping/PITR.)

cierra: ● DR/continuidad del central

16.0c Guarda de compat de esquema en runtime

PR directo

S

Al abrir, si `user_version > latestSchemaVersion()` (ya existe, hoy solo en tests), negarse o abrir read-only con warning. Fixtures de DB pre-migración en CI. Previene corrupción en flota mixta laptop/PC/central.

cierra: ● migraciones/compat runtime

Exit: tag publicado con artefactos verificables; restore del central probado; un binario viejo se niega ante una DB más nueva.

MODELO DE EQUIPO **Multi-tenant, revocable, con borde de confianza explícito**

2-4 semanas · SDD

Que el “cerebro compartido” sea realmente de equipo: aislado por proyecto, con identidad por-miembro y sin secretos crudos en el central. Es el eje donde la vara es más alta y el sistema más débil.

16.1a Atribución autenticada

SDD

M

Derivar `project_id` (y principal) de la credencial presentada, no del payload auto-declarado. Persistir el `project_id` de origen en el ingest en vez de sobrescribirlo (`methods.go:111-118` , `operations.go:207`).

habilita: ● atribución (base de F3 tenancy)

16.1b Aislamiento por query (fin del cross-project bleed)

SDD

L

Filtro `project_id` /scope a nivel de query en TODOS los paths de lectura, detrás del seam ya preparado en `scope.go:32` (recall/prime/context/consolidate). Tests de aislamiento A-no-ve-B.

cierra: ● multi-tenancy / bleed

depende de → 16.1a

16.1c Identidad por-principal + authz + audit

SDD

L

Reemplazar el bearer único por N tokens con etiqueta+claims (project+rol), revocables/rotables desde el central. Authz mínima por operación (lectura vs escritura vs destructiva). Audit log append-only (principal, op, obs_id, ts) .

cierra: ● identidad/authz/auditoría

16.1d Redacción forzada server-side

SDD

M

Flag `Service.ForceRedact` (on por default cuando el bind es no-loopback): en el ingest del central, REDACTAR SIEMPRE o RECHAZAR `scope=local` , independiente del scope declarado. Cierra el hueco de `operations.go:173-182` sin tocar el borde local.

cierra: ● borde de confianza / ingest crudo

16.1e Hardening del borde + threat model

PR directo

S

Threat model documentado (borde de confianza tailnet=confiable, qué cubre WireGuard y qué no). Rate-limit/lockout tras N 401 en el path de auth. ACLs de Tailscale que limiten el puerto del brain a principals concretos.

cierra: ● threat model ● superficie HTTP ● least-privilege red

Exit: un segundo tenant se onboardea sin ver memoria ajena; token por-miembro revocable; secreto crudo imposible en el central; hay audit trail.

Cumplir el diferenciador declarado, con evidencia

2-3 semanas · SDD

Prender la memoria semántica model-free y probar que no regresa la calidad. Hoy medio sistema (embeddings/IVF/RRF) es código latente y lo auto-capturado es invisible al vector.

16.2a Harness de calidad de recall (PRIMERO)

SDD

M

Golden-set etiquetado propio (o subset LongMemEval/LOCOMO) que reporte `nDCG@k` / `precision@k` con gate de regresión en CI. Es el prerequisite de medición: sin esto, encender a ciegas puede regresar la relevancia.

cierra: ● medición de calidad

16.2b Encender el recall semántico por default

SDD

M

Embeber (o auto-descargar con checksum) una tabla POTION/model2vec chica; `Provider:'static'` como default, `'none'` como opt-out explícito. Enciende embeddings + IVF + RRF vectorial hoy inertes.

cierra: ● recall semántico apagado

depende de → 16.2a (medir antes de flipear)

16.2c Paridad de embeddings en la captura

SDD

M

Dar embedder al proceso de turn/capture (o rutear esas escrituras/lecturas por el daemon). Embeber C3 (`capture.go:180`), C4 (`methods.go:1416`) y el prompt en `buildTurnRecall`. Backfill de lo capturado con nil.

cierra: ● paridad embeddings C3/C4

16.2d Contradicciones: no servir memoria stale

PR directo

M

Demote/anotar en el ranking del recall las observaciones con conflicto `pending` sin resolver (`conflicts.go`). La detección ya corre cross-topic; falta que el recall la respete.

cierra: ● contradicciones/staleness

Exit: recall semántico ON con nDCG medido y sin regresión en CI; nada auto-capturado queda invisible al vector; las contradicciones no se inyectan silenciosas.

OPERABILIDAD A ESCALA **Observable, acotado y validado a volumen**

2-3 semanas

Volver el servicio observable, con crecimiento acotado y validado en el régimen para el que fue diseñado. Estos gaps no rompen hoy — rompen a volumen de equipo real.

16.3a Observabilidad accionable en /metrics

PR directo

M

Exponer `OutboxHealth` (pending/dead/oldest_pending_age) + DB size + p95 recall como gauges/counters Prometheus; alerta de lag. El struct ya existe (`outbox.go:267`): es cablear el render.

cierra: ● observabilidad

16.3b Crecimiento acotado por diseño

SDD

M

Cuota (filas/bytes) por `project_id` con expulsión LRU, independiente de la protección por importancia. Purga de filas outbox 'sent' /huérfanas en Maintain. Uso vs cuota en /metrics.

cierra: ● cuota/crecimiento

se apoya en → 16.1a (`project_id` autenticado)

16.3c Validación a escala + RAM acotada

SDD

L

Benches del IVF a `n=100k` (sampled 1M) que fuercen el path entrenado, midiendo p50/p95 y recall@k vs full-scan, con gate de perf en CI. Pagar `Consolidate` y acotar `loadActiveVectors` por lotes.

cierra: ● RAM a escala ● validación IVF

16.3d FTS5 external-content + tokenizer

PR directo

M

Migrar a FTS5 external-content (elimina la copia 2x). Fix inmediato: trigger `AFTER UPDATE OF content`.

Tokenizer `unicode61 remove_diacritics 2 + prefix='2 3'`; índice de recencia para el hot-path.

cierra: ● FTS footprint ● FTS tokenizer

16.3e Costo del proceso efímero

PR directo

M

Gatear `BackfillOutbox` por un flag en meta (solo si hay filas shared sin propagar) en vez de correrlo en cada open. Considerar rutar la captura del hook al daemon vía IPC.

cierra: ● concurrencia/proceso efímero

Exit: /metrics alerta el lag del sync; el footprint está acotado por cuota; el IVF está probado a 100k con gate de perf; la apertura de la DB no re-escanea en cada hook.

Que un tercero instale, opere y forkee sin la infra del autor

2-3 semanas

Los cimientos ya están; lo que falta para "producible" es que Musubi deje de estar atado al autor.

16.4a CI matriz + perfil de seguridad

PR directo

M

`strategy.matrix` con windows-latest + macos-latest (producto Windows-first). gosec/bodyclose scopeados a red/SQL/secretos. Pinear `govulncheck` / `goversioninfo`. Piso de cobertura por-paquete.

cierra: ● CI plataforma ● CI higiene

16.4b Quitar defaults personales

PR directo

M

Quitar `DefaultBrain=100.79.126.62:7717` (`probe.go:15`): exigir `--brain` / `MUSUBI_BRAIN` sin IP embebida. Parametrizar `repoOwner/repoName` (`update.go:15`) por build var.

cierra: ● adopción por terceros

16.4c Docs bilingües + runbooks

PR directo

M

README/runbooks en inglés (o bilingües): restore, upgrade, rotación de token. Fix docs 3→4 hooks (falta el Stop/C3). Automatizar los enlaces del CHANGELOG en el script que corta el tag.

cierra: ● docs drift

16.4d Provisioning completo (P3/P4) + robustez

SDD

L

Que `provision` instale/una Tailscale él mismo (o falle-cerrado). Completar P3 (dev tools) y P4 (repos+git/ssh). Reportar setup local parcial en el veredicto. Detectar NordVPN antes de aplicar el fix. Definir continuidad del scope local por-usuario (o documentar que solo shared es portable).

cierra: ● provisioning de cero ● continuidad multi-máquina ● provisioning robustez ● onboarding DX

16.4e Redacción a paridad gitleaks

PR directo

M

Detectores de alta señal (Slack, GCP-SA-JSON, DSN/connection strings, PII, hex de longitud típica). Endurecer `env-secret` para valores con espacios/comillas y el allowlist a match sobre contexto. Fuzzear `internal/redact`; documentar qué cubre y qué no.

cierra: ● cobertura de redacción

Exit: CI ejercita Windows; cero defaults personales en el binario; docs con runbooks completos; “instalar = máquina lista” se cumple o la promesa se recorta con honestidad.